

통 보

1. 제 목 : 사설 IP 미사용 및 공인 IP 사용에 따른 정보보안에 관한 사항

2. 관계기관 : ○●○○○병원

3. 내 용

가. 업무개요

○●○○○병원에서는 전산 자원의 안정적 운영과 개인정보 유출방지, 외부 사이버 위협으로부터 내부망을 보호하기 위하여 방화벽, 침입차단시스템 등 다양한 정보보안 인프라를 구축·운영하고 있습니다.

나. 관계법령 및 판단기준

「개인정보보호법」 제29조(안전조치의무)에 따르면 개인정보처리자는 개인정보의 안전성을 확보하기 위하여 접근통제, 암호화, 접근기록 보관 등 기술적·관리적 보호조치를 하여야 합니다.

IP주소는 네트워크 접근의 기본 식별자로서, 적절한 주소 관리와 외부 노출 차단은 필수적인 보호조치입니다.

그리고, 공단 「정보보안업무 처리지침」 제29조(내부망·인터넷망 분리) 제3항에 따르면 소속기구의 장은 비인가자로부터 내부망을 보호하기 위하여 네트워크주소변환기(NAT)를 이용하여 사설IP주소¹⁾ 체계를 구축·운영하여야 하며, IP주소별로 정보시스템 접속을 통제하여야 한다고 규정하고 있고,

「정보화업무운영지침」 제53조 제1항에서도 내부 정보통신망은 사설 IP주소를 사용하고, 외부 정보통신망은 공인 IP주소 또는 사설 IP주소를 사용한다고 명시되어 있습니다.

1) 사설 IP(Private IP): 외부 인터넷이 아닌 기관 내부에서만 사용되도록 정해진 IP 주소로, 내부망 장비 식별용으로 사용 (예: 192.168.x.x, 10.x.x.x 등)

또한, 한국인터넷진흥원(KISA) 및 행정안전부의 「행정기관 도메인이름 및 IP주소체계 표준」에서는 RFC1918)에 정의된 대역만을 행정기관 내부용 IPv4주소로 사용하도록 규정하고 있고, 사실 IP 대역(**.*)/*, **.*.*/**, **.*.*/**)은 내부망에서만 사용하여야 하며, 공인 IP는 공식기관으로부터 할당받아 외부 통신용으로만 사용해야한다고 규정하고 있습니다.

따라서 〇〇〇〇병원의 내부 업무망에 사용되는 IP주소는 반드시 사실 IP 대역으로 구성되어야 하며, 외부와의 연계가 필요한 일부 시스템에 대해서만 네트워크 주소변환기(NAT) 또는 DMZ(외부에 오픈된 서버영역) 구간을 통해 공인 IP주소를 제한적으로 할당하는 방식으로 운영하여야 합니다.

다. 감사결과 확인된 문제점

그런데 20**년 〇〇〇〇병원 종합감사 시 정보통신망을 확인한 결과, 내부PC, 서버, 보안장비 등 내부망 장비들이 사실 IP가 아닌 공인 IP(**.*.*/**)를 주소로 사용하고 있는 것을 확인하였습니다.

또한 이 IP들은 공식기관으로부터 할당받은 공인 IP가 아님에도, 전산망 전반에 내부 주소용으로 사용되고 있습니다.

망분리를 통해 외부 인터넷과 직접 연결되지는 않고, 외부와의 통신이 필요한 경우 NAT를 통해 다른 공인 IP로 변환되어 통신이 이루어지는 구조이긴 하나, 내부 식별 주소 자체가 공인 IP로 구성되어 있다는 점은 정보보안상 취약점이 있습니다.

4. 관계기관 의견

〇〇〇〇병원에서는 감사결과를 수용하여 별다른 의견을 제시하지 않았습니다.

2) RFC1918: 사실 IP(Private IP) 주소를 정의한 국제 기술 표준

5. 조치할 사항

○ ●●●●●♠♠♠은

- 내부 PC, 서버, 보안장비 등 내부망 장비가 행정기관 내부용 IPv4 주소로 규정된 주소만 사용할 수 있도록 대책 방안을 마련하여 주시기 바랍니다 (통보)